



13 March 2024

Blog

ISO 27001

 [Share article](#)

[ISO 27001](#) is the international standard for information security. Its framework requires organisations to identify information security risks and select appropriate controls to tackle them.

Clauses 4–10 of the Standard define the broader requirements for an ISMS (information security management system). However, they don't specify individual controls.

Annex A of ISO 27001 takes a different approach.

This blog explains:

- How Annex A works;
- What the Annex A controls are;
- How to select controls from Annex A;
- What the Statement of Applicability is; and
- The difference between ISO 27002 and Annex A.

Call us

My Account

[Get a quote](#) →

What is Annex A in ISO 27001?

Annex A contains a list of 93 security controls, grouped into 4 themes:

1. Organisational
2. People
3. Physical
4. Technological

Please note that this is different to the 2013 iteration of the Standard. That version of Annex A contained 114 controls divided into 14 domains.

What are the Annex A controls of ISO 27001:2022?

Breaking them up into the 4 themes, we have:

Organisational (37 controls)

Get a quote →

They include:

- The information security policy and other core policies;
- Defined responsibilities for management and the people responsible for operating the ISMS day to day;
- Contact with authorities and other relevant groups;
- Threat intelligence and monitoring;
- Classifying and labelling information;
- Identity and access control; and
- Asset management.

People (8 controls)

People, particularly employees, are a critical part of the information security equation.

The controls include:

- Pre-employment screening;
- [Staff awareness](#) and training;
- Contracts and NDAs (non-disclosure agreements);
- Remote working; and
- Reporting security events.

Physical (14 controls)

Call us

My Account

Get a quote →

important as the digital environment for ensuring information security.

The controls relate to, among other things:

- Security perimeters and secure areas;
- Clear desks and screens;
- Supporting utilities;
- Secure cabling; and
- Equipment maintenance.

Technological (34 controls)

Technological controls are what most people think of when they think about information security.

The controls include:

- Malware protection;
- Backups;
- Logging and monitoring;
- Network security and segregation; and
- Development and coding practices.

[Get a quote](#) 

Implementing an ISMS can seem complex, but our comprehensive guide simplifies the process. Download our free paper, “ [Implementing an ISMS – The nine-step approach](#) ,” to gain practical insights and expert advice on building a robust information security management system.

[Download now](#)

How do I select Annex A controls?

The controls in Annex A provide a basis for an effective ISMS, but you shouldn't treat them as gospel.

You select information security controls based on your risk assessment. Then, you compare them against Annex A to ensure you've covered all your risks.

You may exclude Annex A controls that don't apply to your organisation. However, you must justify any exclusions in your SoA (Statement of Applicability).

Get a quote →

The SoA is one of the most important documents in your ISMS.

It lists all Annex A controls, together with:

- Justifications for their inclusion or exclusion; and
- Their implementation status.

If you use controls from other frameworks and/or develop additional controls, you must also list those on your SoA.

The SoA will be a key focus during certification and surveillance audits by your chosen certification body.

The SoA must contain a huge amount of information. It must also be accessible. Many organisations use spreadsheet software, but there's nothing preventing you from exploring [alternative software](#).

The SoA is one of the most important, comprehensive documents in your ISMS, which you must carefully maintain. You should treat it as documented information, so use version control and review it at regular intervals.

[Get a quote](#) →

[ISO 27002](#) assists with effective ISO 27001 implementation – including Annex A – as it describes each control in more detail. This helps organisations better understand the purpose of the controls and how to implement them.

However, organisations can't achieve certification against ISO 27002, only ISO 27001. Nevertheless, ISO 27002 is an essential companion to any organisation implementing an ISO 27001 ISMS.

Looking to effortlessly select Annex A controls?



CyberComply allows you to automate, review and repeat risk assessments.

[Call us](#)[My Account](#)

Get a quote 

Take advantage of CyberComply's built-in library of controls to treat risks.

Find out more

Get a quote 

Help & Support

Company

Tools & Platforms

Legal & Governance

Get in touch 

